

BUILD WEEK 3

Esercizio 6 — Analisi di Log e Traffico di Rete

Team Amaterasu

Obiettivi

- Analizzare log e catture di traffico pre-catturati
- Estrarre file scaricati dal PCAP

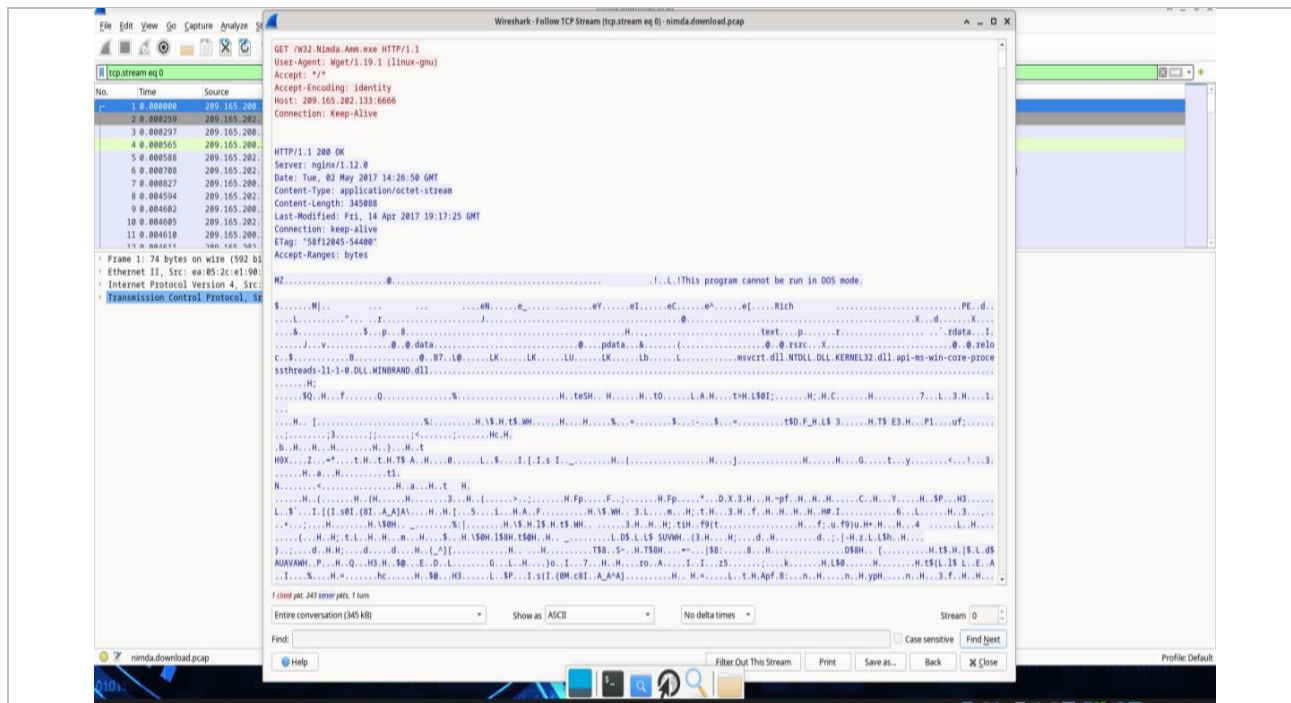
Risorse richieste

- VM Cyberops Workstation

Parte 1 — Analizzare log e catture di traffico pre-catturati

Domanda 1

D Cosa sono tutti quei simboli mostrati nella finestra Follow TCP Stream? Sono rumore di connessione? Dati? Spiega. Ci sono alcune parole leggibili sparse tra i simboli. Perché sono lì?



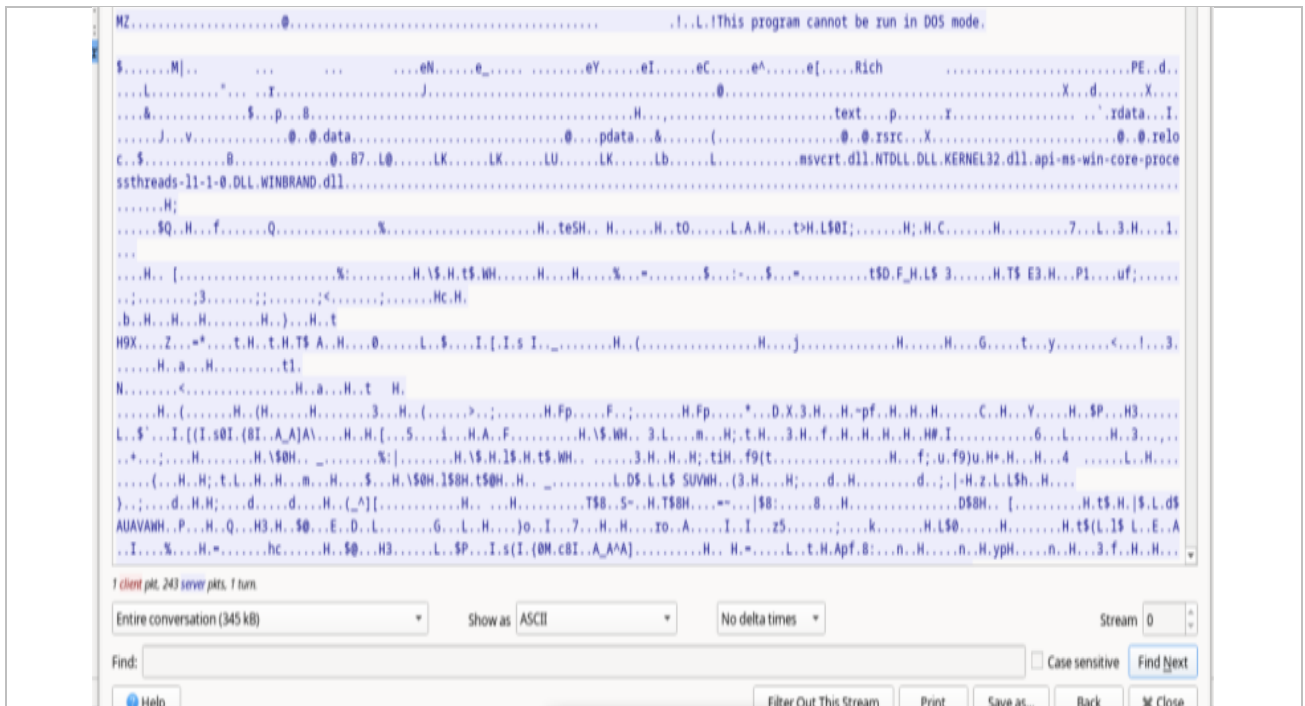
R

I simboli mostrati nella finestra Follow TCP Stream rappresentano il codice binario dell'eseguibile malevolo scaricato tramite la sessione HTTP, non un errore o un rumore di connessione. Poiché i file eseguibili sono scritti in linguaggio macchina e non in formato testo, Wireshark tenta di interpretare ogni singolo byte del payload convertendolo forzatamente nella tabella dei caratteri ASCII; la maggior parte di questi byte non corrisponde a lettere o numeri e viene quindi visualizzata sotto forma di caratteri speciali e simboli non stampabili.

Le poche parole leggibili in chiaro distribuite all'interno del flusso sono stringhe di testo incorporate nel programma stesso, necessarie al suo funzionamento sul sistema operativo. Tra queste si trovano le intestazioni standard degli eseguibili per Windows (come la firma "MZ" e il messaggio "This program cannot be run in DOS mode"), i nomi delle librerie DLL e delle funzioni di sistema che il malware richiama per infettare la macchina, oltre a eventuali messaggi di errore, chiavi di registro, indirizzi IP o domini integrati direttamente nel codice dal creatore del malware.

Domanda Sfida

D Nonostante il nome W32.Nimda.Amm.exe, questo eseguibile non è il famoso worm. Per motivi di sicurezza, questo è un altro file eseguibile che è stato rinominato come W32.Nimda.Amm.exe. Usando i frammenti di parole visualizzati dalla finestra Follow TCP Stream di Wireshark, puoi dire quale eseguibile sia realmente?



R

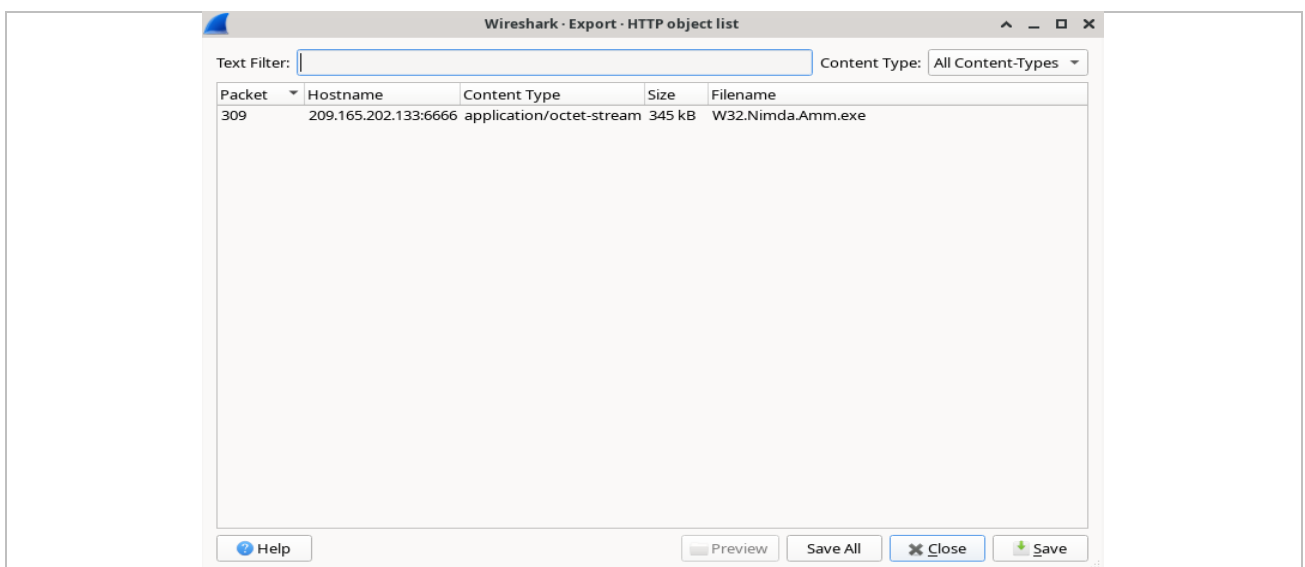
L'eseguibile reale nascosto sotto il falso nome di W32.Nimda.Amm.exe è cmd.exe (il Prompt dei comandi di Windows). Questa certezza deriva dai frammenti di testo identificati nel flusso TCP, che evidenziano l'importazione di librerie di sistema fondamentali come KERNEL32.dll, NTDLL.DLL, msvcr7.dll e in particolare WINBRAND.dll (Windows Branding Resource), una DLL specifica richiamata dall'interprete dei comandi di Windows per mostrare la versione e il marchio del sistema operativo.

La combinazione di queste API con l'header nativo MZ dimostra che si tratta dell'eseguibile originale di sistema, adoperato nel laboratorio come payload innocuo per simulare l'analisi di rete in totale sicurezza.

Parte 2 — Estrarre file scaricati dal PCAP

Domanda 1

D Perché W32.Nimda.Amm.exe è l'unico file nella cattura?

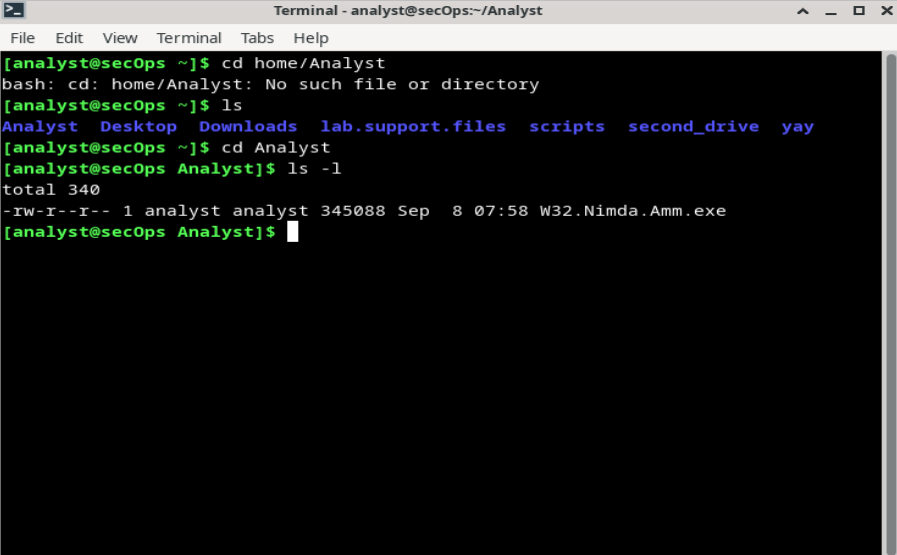


R

W32.Nimda.Amm.exe è l'unico file presente nella cattura perché l'attività di registrazione del traffico tramite tcpdump è stata avviata esclusivamente per isolare l'operazione di download del malware ed è stata terminata subito dopo. Durante l'intervallo di cattura, l'host ha generato una singola richiesta HTTP GET per quel file specifico senza effettuare altra navigazione web o trasferimenti di risorse aggiuntive (come immagini, script o altre pagine web), rendendo quella transazione l'unico oggetto HTTP registrato nel file pcap.

Domanda 2

D Il file è stato salvato?



```
Terminal - analyst@secOps:~/Analyst
File Edit View Terminal Tabs Help
[analyst@secOps ~]$ cd home/Analyst
bash: cd: home/Analyst: No such file or directory
[analyst@secOps ~]$ ls
Analyst Desktop Downloads lab.support.files scripts second_drive yay
[analyst@secOps ~]$ cd Analyst
[analyst@secOps Analyst]$ ls -l
total 340
-rw-r--r-- 1 analyst analyst 345088 Sep  8 07:58 W32.Nimda.Amm.exe
[analyst@secOps Analyst]$
```

R

Sì, il file è stato salvato correttamente.

Domanda 3

D Nel processo di analisi del malware, quale sarebbe un probabile passo successivo per un analista di sicurezza?

R

Il passo successivo nel processo di analisi del malware è l'esecuzione dell'Analisi Statica Base. In questa fase, l'analista calcola innanzitutto l'hash del file (tramite comandi come sha256sum o md5sum) per verificarne la reputazione su database di Threat Intelligence come VirusTotal e controllare se l'eseguibile sia già noto.

Contestualmente, si utilizza il comando strings o un analizzatore di PE header per estrarre gli indicatori di compromissione (IoC) presenti nel codice, come indirizzi IP, URL di Command & Control, chiavi di registro e funzioni di sistema importate.

Qualora l'analisi statica non fornisca dettagli sufficienti, si passa all'Analisi Dinamica Base, eseguendo il file all'interno di un ambiente isolato (Sandbox o macchina virtuale dedicata) per osservarne il comportamento in tempo reale, monitorando la creazione di processi, le modifiche al file system e le eventuali connessioni di rete generate.